UNIVERSIDAD AMERICANA
FACULTAD DE INGENIERÍA Y ARQUITECTURA



Ingeniería en Sistemas de Información

Diseño Web

Práctica Guiada Semana 9

Estudiante:

Emilio Jose Carranza Rivera

Profesor:

José A. Durán G

1. ¿En qué se diferencian HTTP 401 y 403?
   401 Unauthorized: Ocurre cuando la petición carece de credenciales válidas de autenticación (sin token, token malformado o expirado). El servidor no reconoce la identidad del cliente.

   403 Forbidden: Ocurre cuando el cliente está correctamente autenticado, pero carece de las autoridades o roles necesarios para acceder al recurso (por ejemplo, el rol USER intentando un POST reservado para ADMIN).

2. **¿Por qué no basta con leer el contenido de un JWT para confiar en él?**
   Porque las secciones de Header y Payload de un JWT solo están codificadas en Base64, permitiendo que cualquiera las lea o altere. La validez y seguridad del token residen en su firma criptográfica (Signature), la cual garantiza que la información no ha sido modificada por terceros desde que fue emitida por el servidor.

3. **¿Qué función cumple?**
   Se encarga de verificar la integridad de la firma criptográfica del JWT utilizando la clave secreta o pública configurada, validar los tiempos de vigencia (exp, nbf) y transformar las demandas (claims) contenidas en el JSON en un objeto Jwt manejable por el contexto de seguridad de Spring Security.

4. **¿Qué riesgos ocasionaría publicar la clave utilizada para firmar tokens?**
   Comprometer la clave secreta (utilizada en algoritmos simétricos como HS256) permite a cualquier atacante generar y firmar JWTs fraudulentos con cualquier rol (incluyendo ROLE_ADMIN) o identidad, tomando control total sobre el sistema de autorización y vulnerando la seguridad de la aplicación.